

 **Servicio 02-A: Auditoría Técnica de Seguridad Web e infraestructura Multi-Activo (Validación de explotabilidad).**

 **Problema a Solucionar:** La implementación de un Web Application Firewall (WAF) perimetral es inútil si una parte de la infraestructura de origen (backend) sigue siendo accesible directamente desde internet. Los atacantes pueden utilizar el historial de registros DNS y la inspección de certificados SSL entre otras herramientas para descubrir las direcciones IP reales de los servidores hospedados en diferentes proveedores, permitiéndoles evadir por completo los controles de inspección del WAF y lanzar ataques directos contra servicios internos obsoletos (como LDAP, bases de datos o paneles de correo).

 **Metodología Aplicada:** Pruebas de penetración externas dirigidas bajo el estándar PTES (Penetration Testing Execution Standard). Incluye actividades de pentesting controlado, validación de vulnerabilidades y pruebas de explotación autorizadas con límites bien definidos para minimizar la afectación del negocio.

1. Elusión Perimetral (WAF Bypass): Análisis de DNS histórico y Header Host Injection para descubrir IPs de origen ocultas.
2. Escaneo de Infraestructura Avanzado: Uso de **nmap** con implementación de técnicas de elusión para reducir la probabilidad de detección y sobre carga del servidor con el fin de mapear puertos expuestos sin activar bloqueos dinámicos.
3. Validación Activa de Vulnerabilidades (PoC): Ejecución controlada de “payloads” e interrogación de servicios para confirmar la explotación real de fallos de configuración y software heredado.
4. Análisis de Capas de Mitigación: Evaluación de controles compensatorios (ACLs de bases de datos, proxies inversos) que detienen exploits públicos.

 **Resultados Obtenidos (Caso de Estudio Muestra):** El objetivo evaluado, un ecosistema web distribuido en varios proveedores de infraestructura (3 identificados) al que se le asigna un índice de Riesgo Técnico (IRT): 51/100 (Riesgo Medio-Alto).

Vectores de Ataque Confirmados:

Bypass Exitoso de Cloudflare WAF. Se logró acceder a infraestructura de origen evitando completamente la protección proporcionada por Cloudflare WAF mediante técnicas de identificación de infraestructura histórica y resolución de servicios backend.

Acceso directo al panel de administración de correo electrónico sin pasar por los controles de protección perimetral, permitiendo intentos de autenticación y reconocimiento sobre la plataforma.

Extracción de Estructura de Directorios (LDAP Anonymous Bind). Permite la enumeración de usuarios y recursos del dominio abriendo la posibilidad de phishing dirigido.

Recopilación pasiva de metadatos de configuración y componentes tecnológicos del activo facilitando la búsqueda de vulnerabilidades específicas y vectores de ataque dirigidos.

Exposición de Gestión Insegura. Puertos innecesarios abiertos que permiten interactuar directamente con servicios críticos como la BDD.

Protocolo VNC interactuando en texto claro (RFB 003.008). La comunicación observada carece de mecanismos de cifrado adecuados, incrementando el riesgo de exposición de credenciales, sesiones e información sensible durante la transmisión.

Fortalezas Identificadas: Mitigación correcta de ataques “Drupalgeddon2” vía configuración de Nginx y filtrado estricto del puerto SMTP (25/587).

 **Herramientas Utilizadas:** nmap (Mapeo e identificación de servicios). ldapsearch (Interrogación y extracción de estructuras OpenLDAP). curl (Inyección de payloads HTTP y verificación de mitigaciones). Historiales DNS públicos (crt.sh) y plataformas de inteligencia de amenazas.

Lecciones aprendidas: El servicio de protección perimetral más fuerte puede llegar a ser inutilizado si se deja una sola brecha abierta. Esto puede pasar por cosas tan simples como, activos olvidados, puertos de comunicación abiertos sin justificación o aplicación de políticas de seguridad segmentadas (no aplicadas a toda la infraestructura).

 **Valor para la organización:** Un proceso de auditoría temprana ayuda a identificar puntos débiles en la infraestructura como activos olvidados, mal configurados o expuestos innecesariamente, además de validar controles implementados correctamente, reduciendo falsos positivos y enfocando los esfuerzos de remediación en los riesgos con mayor impacto potencial optimizando el uso de los recursos disponibles.

La inversión en prevención suele ser menor al costo de corregir o solucionar problemas.